

04 — Secure Azure using Defender for Cloud and Sentinel (30–35%)

The largest domain. Note the structure — it is wider than its name suggests. Four official subsections:

1. **Implement and manage enforcement of cloud governance policies** — Azure Policy, **Key Vault**, backup security, asset management
2. Manage security posture by using Microsoft Defender for Cloud
3. Configure and manage threat protection by using Microsoft Defender for Cloud
4. Configure and manage security monitoring and automation solutions — DCRs, **Sentinel**

Rough internal split: **governance + Defender for Cloud** $\approx$ 80%, **Sentinel** $\approx$ 20%.

Part A — Governance

1. Azure Policy

Azure Policy vs Azure RBAC: RBAC controls **who can do things**; Policy controls **what the resulting resource is allowed to look like**. A user with Owner rights is still blocked by a Deny policy.

Structure

Policy definition (one rule) → **Initiative / policy set** (a bundle of definitions) → **Assignment** (definition or initiative applied at a **scope**) → **Exemption** (carve-out) → **Remediation task** (fix existing resources).

Scopes: **management group** → **subscription** → **resource group** → **resource**, inherited downward. Assignments can have **exclusions** (a sub-scope not evaluated).

Effects — memorise these, they are heavily tested

Effect	Behaviour	When it evaluates
Deny	Blocks the create/update request	At request time — prevention
Audit	Allows it, creates a non-compliant entry	At request time + on evaluation
AuditIfNotExists	Audits when a related resource is missing (e.g. no diagnostic setting, no VM extension)	After resource creation
DeployIfNotExists (DINE)	Deploys the missing related resource	After resource creation; needs a managed identity
Modify	Adds, updates, or removes properties or tags on the resource itself	At request time; needs a managed identity
Append	Adds fields to the request (legacy; prefer Modify)	At request time
Disabled	Turns the policy off without unassigning	—

DenyAction	Blocks a specific action , notably <code>delete</code>	On the action
Manual	Manually attested compliance (for non-technical controls)	—

DINE and Modify need a managed identity on the assignment, with sufficient RBAC. If a scenario says "the policy assignment fails to remediate", the answer is usually **the managed identity lacks permissions** or **a remediation task was never created**.

New vs existing resources: Deny/Modify only affect **new or updated** resources. To fix **existing** resources you must create a **remediation task** (DINE/Modify) — this is a classic exam gap.

Compliance

- Evaluation runs on resource change and on a **~24-hour cycle**; can be triggered on demand (`Start-AzPolicyComplianceScan`).
- **Compliance state:** Compliant, Non-compliant, Conflicting, Not started, Exempt.
- **Exemptions** with categories **Waiver** (accepting the risk) and **Mitigated** (handled another way), plus an optional expiry date. Exemptions are the modern replacement for Defender for Cloud "disable rules".
- Definition structure: `if` (conditions on `field`, `allOf`, `anyOf`, `not`) → `then` (effect + details). Uses **aliases** to reference resource properties (`Microsoft.Storage/storageAccounts/supportsHttpsTrafficOnly`).
- **Parameters** make definitions reusable (e.g. allowed locations list) and support `strongType`.

Notable built-in initiatives

- **Microsoft Cloud Security Benchmark (MCSB)** — the default security initiative assigned by Defender for Cloud to every

subscription. This is what drives your **Secure Score**.

- Regulatory initiatives: NIST SP 800-53 Rev. 5, PCI DSS v4, ISO/IEC 27001:2022, CIS Azure Foundations, SOC 2, HIPAA HITRUST, FedRAMP.

2. Azure Key Vault

The two planes

- **Control plane** — manage the vault itself (create, delete, configure networking). Azure RBAC only. Roles: Contributor, Key Vault Contributor.
- **Data plane** — work with keys, secrets, and certificates. Governed by **either** RBAC **or** access policies.

Access model — RBAC vs access policies

	Azure RBAC (recommended)	Vault access policy (legacy)
Granularity	Roles at vault scope, and individual key/secret/certificate scope (read operations only)	Per-principal permission lists at vault level only
Managed where	Access control (IAM) — the same place as all other Azure access	The vault's Access policies blade
Supports PIM / just-in-time	✓ Yes	✗ No
Supports deny assignments, Azure roles, ARM audit trail	✓	✗

Limits	Standard RBAC limits	1,024 access policy entries per vault
--------	----------------------	--

Microsoft's current guidance: use Azure RBAC. Legacy access policies "have known security vulnerabilities and lack support for PIM" — do not use them for critical workloads. The exam objective explicitly says "including vault access policies **and** Azure RBAC", so know both, but pick RBAC when asked for best practice.

Key RBAC roles: Key Vault Administrator (all data ops), Key Vault Reader (read metadata, **not** secret values), Key Vault Secrets User (**read secret contents**), Key Vault Secrets Officer, Key Vault Crypto User, Key Vault Crypto Officer, Key Vault Certificates Officer.

Trap: Key Vault Reader can see that a secret exists but **cannot read its value**. Reading values needs Key Vault Secrets User.

Access policy permissions are three separate lists — Key permissions, Secret permissions, Certificate permissions — with operations like get, list, set/create, delete, recover, backup, restore, purge, and for keys: encrypt, decrypt, **wrapKey**, **unwrapKey**, sign, verify.

Special toggles (needed for other services to use vault keys):

- **Enabled for deployment** — ARM can retrieve certificates when deploying VMs.
- **Enabled for disk encryption** — **required for Azure Disk Encryption (ADE)**.
- **Enabled for template deployment** — ARM templates can pull secrets.

Data protection

- **Soft delete** — **enabled by default and cannot be disabled** on new vaults. Retention is configurable **7–90 days** (default 90). Deleted objects and vaults go to a recoverable state; `recover` or

purge them.

- **Purge protection** — while retention is running, **nobody can purge**, not even a subscription owner. **Once enabled, it cannot be turned off** for that vault. Required by ADE with CMK, disk encryption sets, SQL TDE with BYOK, and storage CMK.
- **Backup/restore** of individual keys, secrets, certificates — produces an encrypted blob restorable **only into a vault in the same subscription and geography**.

Networking

Firewall → selected networks (IP rules + VNet rules) → **private endpoint** (`privatelink.vaultcore.azure.net`) → **publicNetworkAccess = Disabled** → **Network Security Perimeter** (most restrictive; `SecuredByPerimeter` overrides the trusted-services bypass). **"Allow trusted Microsoft services to bypass this firewall"** is the fix when Backup, Defender, ADE, or ExpressRoute MACsec is being blocked.

Keys, secrets, certificates, and rotation

- **SKUs: Standard** (software-protected keys) · **Premium (HSM-backed, FIPS 140-2 Level 2 validated)** · **Managed HSM** (single-tenant, fully managed HSM pool, **FIPS 140-2 Level 3**, with its own local RBAC and a security-domain download you must protect).
 - **Key rotation policy** — automatic rotation at a set interval with expiry notification events (Event Grid). Certificates support **autorotation** and integrated CA issuance (DigiCert, GlobalSign) or self-signed.
 - **BYOK** — import an externally generated, HSM-wrapped key.
 - **Key Vault references** in App Service/Functions:
`@Microsoft.KeyVault(SecretUri=https://vault.vault.azure.net/secrets/name/version)`, resolved using the app's **managed identity**.
 - **Logging**: enable diagnostic settings for the **AuditEvent** log category → Log Analytics. **Defender for Key Vault** alerts on unusual access patterns.
-

Part B — Microsoft Defender for Cloud

3. The two halves: CSPM and CWPP

	CSPM — posture (are we configured correctly?)	CWPP — workload protection (are we under attack?)
Delivers	Secure score, recommendations, compliance, attack paths, inventory	Threat detection, alerts, EDR, vulnerability scanning
Tiers	Foundational CSPM (free) and Defender CSPM (paid)	The per-resource Defender plans

Foundational CSPM — free, on by default

Continuous assessment, **Secure Score**, **security recommendations**, the **MCSB** initiative assignment, asset inventory, and connectors for AWS/GCP.

Defender CSPM — paid

Adds:

- **Attack path analysis** — chains of misconfigurations that form a real exploitable route (e.g. internet-exposed VM → high-severity vuln → managed identity with Owner on the subscription).
- **Cloud Security Explorer** — graph query interface over the **cloud security graph** to hunt posture issues.

- **Agentless scanning** for VMs — vulnerabilities, software inventory, **secrets**, and **malware**, via disk snapshot, with no agent.
- **Agentless container posture** and **container registry vulnerability assessment**.
- **Data-aware security posture** — discovers and classifies **sensitive data** in storage and databases, and factors it into attack paths.
- **Code-to-cloud contextualisation** (DevOps).
- **Governance rules** — assign an **owner** and a **remediation due date** to recommendations, with automatic email notification and grace periods. This is the answer to "make resource owners accountable for remediating findings by a deadline".
- **Microsoft Defender External Attack Surface Management (EASM)** — discovers your **internet-facing** assets from the outside, including shadow IT and unknown domains/IPs, and reports exposures. Note: it is a **separate resource** you create and connect, discovering assets from a set of **seeds**.

4. Secure Score

- Built from **security controls** — groups of related recommendations, each with a **maximum score**.
- **You only earn points for a control when *all* resources in it are healthy** — partial remediation of a control earns partial credit proportionally, but the control is only "done" at 100%.
- $\text{Score} = (\text{sum of earned points} / \text{sum of max points}) \times 100$, expressed as a percentage and as points.
- **Recommendations** carry severity (High/Medium/Low), affected resources, and remediation steps; many have a **Fix** (quick fix) button, and some support **Enforce** (assign a DINE policy) or **Deny** (assign a Deny policy) to stop the problem recurring.
- **Exempt** a recommendation or resource with reason **Waiver** or **Mitigated** — exempted resources are **removed from the score calculation**. (Exemptions replaced the old "disable rule".)
- Recommendations come from the **MCSB** initiative plus any custom standards you add.

- **Current change to be aware of:** Defender for Cloud has moved from **grouped recommendations (sub-assessments)** to **individual recommendations**; legacy grouped recommendations were removed from the Azure portal on **31 July 2026**. Exam items written earlier may still use the old phrasing.

5. Regulatory compliance

- Dashboard showing pass/fail against **compliance standards**, mapped from your Azure Policy assessments.
- Available standards include **MCSB (applied by default)**, PCI DSS v4, ISO/IEC 27001, SOC 2 Type 2, NIST SP 800-53 R5, NIST SP 800-171, CIS Azure Foundations Benchmark, HIPAA HITRUST, FedRAMP, plus AWS and GCP equivalents (CIS AWS, AWS Foundational Security Best Practices, CIS GCP).
- **Add a standard:** Environment settings → select subscription → **Security policies** → add a compliance standard.
- **Custom standards** — build your own standard from selected built-in and custom recommendations/policies. The answer to "assess against our internal corporate security policy".
- **Compliance offerings** and downloadable audit reports (PDF/CSV) for auditors.

6. Defender plans (CWPP)

Defender for Servers — verified current

Feature	Plan 1	Plan 2
Multicloud (Azure/AWS/GCP) and on-prem via Arc	✓	✓
Defender for Endpoint auto-provisioning + EDR	✓	✓
Integrated alerts and incidents	✓	✓

Software inventory discovery	✓	✓
Regulatory compliance assessment	✓	✓
Vulnerability scanning (agent-based)	✓	✓
Vulnerability scanning (agentless)	—	✓
Defender for DNS alerts	—	✓
Threat detection at the Azure network layer	—	✓
OS system updates / OS baseline misconfigurations (MCSB)	—	✓
MDVM premium features	—	✓
Malware scanning (agentless)	—	✓
Machine secrets scanning (agentless)	—	✓
File integrity monitoring (FIM)	—	✓
Just-in-time VM access	—	✓
Network map	—	✓
Free data ingestion — 500 MB/day	—	✓

Deployment scope: Plan 1 can be enabled **per resource**; Plan 2 can only be **enabled at subscription level** (but disabled per resource). A **30-day trial** starts on enablement and cannot be paused or extended.

Agent situation (this has changed — get it right): Defender for Servers **no longer uses the Log Analytics agent (MMA) or Azure Monitor Agent (AMA) for most features. Agentless machine scanning** plus the **Defender for Endpoint integration** replace them. AMA remains supported only as the collection method for the **500 MB free data ingestion benefit**. Agentless scanning is **on by default** when you enable Plan 2.

Older study material lists **adaptive application controls** and **adaptive network hardening** as Plan 2 features. They are **no longer in the current plan feature table**. If they appear as an option, treat them as legacy.

Defender Experts for Servers — a managed XDR service (sold separately) layered on Plan 1 or Plan 2: Microsoft analysts triage and contain incidents, plus Defender Experts for Hunting and "Ask Defender Experts". DNS alerts are out of scope.

The other plans

Plan	Protects	Signature capabilities
Defender for Storage	Storage accounts	On-upload malware scanning (powered by Defender Antivirus), sensitive data threat detection , activity monitoring/anomaly detection (unusual access, anonymous access, data exfiltration). Billed per storage account + per GB scanned
Defender for Databases	Azure SQL DB, SQL Server on machines, open-source RDBs (MySQL/ PostgreSQL/ MariaDB), Cosmos DB	Vulnerability assessment + advanced threat protection (SQL injection, brute force, anomalous access)
Defender for Containers	AKS, ARO, EKS, GKE, on-prem/Arc K8s, ACR , ACI	Image vulnerability assessment (registry + running images) via MDVM , runtime threat protection (sensor-based), KSPM , binary drift detection, admission control
Defender for App Service	App Service plans	Detects web-app attacks — dangling DNS, web shells, crypto mining, suspicious process execution

Defender for APIs	Azure API Management APIs	API inventory, sensitive-data exposure, unused/unauthenticated APIs, runtime threat detection (OWASP API Top 10)
Defender for AI Services (formerly AI/Cognitive Services)	Azure OpenAI and Azure AI services	Prompt injection (jailbreak) detection, data leakage, wallet abuse, credential theft
Defender for Key Vault	Key Vaults	Unusual access patterns, suspicious secret enumeration, access from a suspicious IP or TOR
Defender for Resource Manager	The control plane	Suspicious ARM operations mapped to MITRE ATT&CK — exploitation toolkits (MicroBurst/PowerZure), suspicious role assignment, risky exposure

Plan deprecations to be aware of (current): onboarding via the plan-enablement API is now **blocked** for five legacy plans — **Defender for AKS** and **Defender for Container Registries** (→ use **Defender for Containers**), **Defender for DNS** (→ folded into **Defender for Servers Plan 2**), and the legacy per-transaction **Defender for Key Vault** and **Defender for Resource Manager** plans (→ moved to a **fixed pricing model**; the capabilities still exist). No retirement date announced.

DevOps security

Connect **GitHub**, **Azure DevOps**, and **GitLab** to Defender for Cloud to get:

- **Code, secrets, dependency (OSS), and IaC misconfiguration** scanning surfaced as Defender for Cloud recommendations.
- **Code-to-cloud contextualisation** — trace a running vulnerable

container back to the repo and pipeline that built it.

- **Pull request annotations** — findings posted directly into the PR.
- Requires the **Microsoft Security DevOps** extension/action in the pipeline for scan results.

Multicloud connectors

Connect **AWS** and **GCP** accounts/projects to get CSPM plus the Defender plans (Servers, Containers, Databases, CSPM) across clouds. AWS uses an IAM role + CloudFormation; GCP uses workload identity federation. **Azure Arc** is what brings **on-premises and other-cloud VMs** under management for agent-based capabilities.

7. Alerts, automation, and export

- **Security alerts** — severity High/Medium/Low/Informational, mapped to **MITRE ATT&CK** tactics, with an **intent kill-chain**. Actions: **Take action** (mitigation steps), **change status** (Active / Dismissed / **Resolved**), **suppress**.
- **Alert suppression rules** — auto-dismiss known-benign alerts by alert name, resource, entity, or severity.
- **Sample alerts** — generate fake alerts to test your automation. (A frequent exam answer for "how do you validate the workflow without a real attack?")
- **Workflow automation** — trigger a **Logic App** on a **security alert**, a **recommendation**, or a **regulatory compliance assessment** change. The native Defender for Cloud automation mechanism.
- **Continuous export** — stream alerts and recommendations to a **Log Analytics workspace** or an **Event Hub** (Event Hub is the route to a third-party SIEM/Splunk/QRadar). Configurable per subscription, or at scale via Azure Policy.
- **Email notifications** — per subscription, to specified roles (Owner/Contributor) and email addresses, at a chosen severity threshold.

Workflow automation vs Sentinel automation rule: if the trigger is a **Defender for Cloud recommendation or alert**, the answer is

workflow automation. If the trigger is a **Sentinel incident**, the answer is a **Sentinel automation rule**.

Part C — Azure Monitor and DCRs

8. Data collection rules (DCRs)

The modern, **Azure Monitor Agent (AMA)**-based configuration for what telemetry gets collected, from where, and where it goes. AMA replaced the retired **Log Analytics agent (MMA)**.

- A **DCR** defines: **data sources** (Windows Event Logs with XPath queries, Linux **Syslog** facilities and levels, performance counters, IIS logs, custom text/JSON logs), optional **transformations** (KQL that filters or reshapes at ingestion, to cut cost or drop noise), and **destinations** (one or more Log Analytics workspaces, or Azure Monitor Metrics).
 - **Data collection rule associations (DCRA)** bind a DCR to machines. One machine can have **multiple DCRs**; the union of their collection is applied.
 - **DCR endpoints (DCE)** are needed for private-link and some custom-log scenarios.
 - The exam objective is *"monitor network security events and performance data by configuring DCRs"* — so know that **Windows security events (event log Security)** and **performance counters** are collected via a DCR, and that this is how you get `SecurityEvent` data into a workspace for Sentinel.
 - **Diagnostic settings** are the separate mechanism for **Azure resource** logs and metrics (NSG, Key Vault, SQL, Firewall) → Log Analytics / Storage / Event Hub / partner solution.
-

Part D — Microsoft Sentinel

Cloud-native SIEM + SOAR built on a Log Analytics workspace.
Remember: Sentinel *is* a Log Analytics workspace with the Sentinel solution enabled — so workspace RBAC, retention, and cost all apply.

Portal change (current, and likely to appear in newer items)

Sentinel is moving to the **Microsoft Defender portal** as part of the **unified security operations platform**. From **1 July 2026**, Azure portal users are redirected and **new Sentinel environments are created in the Defender portal**. **Azure portal support ends 31 March 2027** (extended from the original July 2026 date).

Two consequences that are directly testable: once you onboard Sentinel to the **Defender portal** or enable **Defender XDR incident integration**, **Microsoft security analytics rules** and the **Fusion** rule are **unavailable and existing ones are auto-disabled** — because **Defender XDR creates the incidents instead**.

9. Roles

Role	Can
Microsoft Sentinel Reader	View data, incidents, workbooks, rules
Microsoft Sentinel Responder	All of the above + manage incidents (assign, change severity, close)
Microsoft Sentinel Contributor	All of the above + create and edit analytics rules, workbooks, and other artefacts

Microsoft Sentinel Automation Contributor	Lets automation rules run playbooks (assigned to the Sentinel service principal)
Logic App Contributor	Needed in addition to create/run playbooks
Microsoft Sentinel Playbook Operator	Run playbooks only

These are **resource-group scoped** roles on the Sentinel workspace. A responder who cannot run a playbook is missing **Logic App Contributor** — a classic scenario.

10. Data connectors

Connector type	Examples	Mechanism
Service-to-service (native)	Microsoft Entra ID (sign-in and audit logs), Azure Activity, Microsoft Defender XDR, Defender for Cloud, Office 365, Azure Firewall, Microsoft Defender for Identity/Office/Endpoint/Cloud Apps	Native API integration, a few clicks

Agent-based (AMA)	Windows Security Events, Syslog, CEF	AMA + a DCR . CEF/Syslog from appliances go via a Linux log forwarder VM running rsyslog/syslog-ng, which forwards to AMA
Codeless Connector Platform (CCP)	Many SaaS products	Config-driven, no code
API / Azure Functions	Custom and third-party	Custom polling code
Logs Ingestion API	Anything custom	Push to a custom table via DCR
Threat intelligence	TAXII servers, Threat Intelligence Upload API (the Graph-based successor to the retired legacy TI Indicators API), MDTI	Populates <code>ThreatIntelligenceIndicator</code>
Windows Firewall / DNS / etc.	Via AMA DCRs	

Connectors are installed as **solutions from the Content hub**. Most connectors write to a specific table — knowing the table matters for KQL questions (see file 07).

11. Analytics rules — the five types (verified current)

Type	How it works	Creates alerts?	Customisable?
Scheduled	A KQL query run on a set schedule over a lookback window; fires when results exceed a threshold	✓	✓ Fully
Near-real-time (NRT)	A limited subset of scheduled rules that runs once every minute	✓	✓ With limits (single table, no unions/joins in most cases, no lookback config)
Anomaly	ML builds a baseline of behaviour, then flags deviations	✗ No alerts — writes to the Anomalies table	Duplicate and tune the copy; run in Flighting mode vs Production
Microsoft security	Automatically creates Sentinel incidents from alerts produced by other Microsoft security products	✓ (incidents)	Filter by product/severity only. Unavailable if Defender XDR incident integration is on or Sentinel is in the Defender portal
Fusion (Advanced multistage attack detection)	ML correlates many low-fidelity alerts and events across products into a few high-fidelity incidents	✓	✗ Logic hidden, one instance only. Enabled by default. Also unavailable under Defender XDR incident integration

ML Behavior Analytics	Microsoft's proprietary ML for anomalous SSH and RDP login behaviour	✓	✗ Not customisable (preview)
Threat Intelligence	Microsoft Threat Intelligence Analytics matches CEF, Syslog, and Windows DNS data against Microsoft's domain/IP/URL indicators	✓	✗ Not customisable

Scheduled rule configuration you should be able to reason about:

- **Query scheduling:** run every X (5 min – 14 days), lookup data from the last Y (5 min – 14 days). Lookback should be $\geq$ frequency or you create gaps.
- **Alert threshold:** generate an alert when the number of results is $>/<$ some number.
- **Event grouping:** *Group all events into a single alert* (default) vs *trigger an alert for each event* (max 150).
- **Entity mapping** — map query columns to entity types (Account, Host, IP, URL, File hash, Process, Mailbox...). **Without entity mapping there is no investigation graph and no UEBA enrichment.** This is a favourite exam point.
- **Custom details** — surface specific event fields onto the alert.
- **Alert details override** — dynamically set alert name/description/severity/tactics from query results.
- **Suppression** — stop running the query for N hours after an alert fires.
- **Incident settings** — create incidents from alerts (on by default) and **alert grouping** (group related alerts into one incident within a time window, by entity/details/all).
- **MITRE ATT&CK** tactics and techniques tagging.

- Rules can be **exported to and imported from ARM templates** for detection-as-code.

Rule templates come from the **Content hub** solutions; activate them rather than writing from scratch when "minimise effort" is in the stem.

Current direction: Microsoft now positions **Custom detections** (in the Defender portal) as the unified way to create new detections across Sentinel SIEM and Defender XDR — cheaper ingestion, unlimited real-time detections, automatic entity mapping. Recognise the name; the exam still primarily tests Sentinel analytics rules.

12. Incidents and investigation

- **Alert** = a single detection. **Incident** = a case file containing one or more related alerts, bookmarks, and entities.
- Incident fields: severity, status (**New** / **Active** / **Closed**), owner, tactics, **classification on close** (True positive – suspicious activity / **Benign positive** – suspicious but expected / False positive – incorrect alert logic / False positive – inaccurate data / Undetermined).
- **Investigation graph** — visual entity exploration; **requires entity mapping** on the rule.
- **Entity pages** and **UEBA** — behavioural baselines for users, hosts, IPs; needs UEBA enabled and specific data sources (`BehaviorAnalytics`, `IdentityInfo` tables).
- **Hunting** — proactive KQL queries with no rule attached; save findings as **bookmarks**; **Livestream** for near-real-time monitoring of a query; **notebooks** (Jupyter + MSTICPy) for advanced analysis. (*Lower exam priority — the outline does not name hunting.*)
- **Watchlists** — imported CSV reference data (VIP users, allowed IPs, terminated employees) queryable via `_GetWatchlist('name')`.

13. Automation — automation rules vs

playbooks

This distinction is the highest-yield Sentinel item on the exam.

	Automation rule	Playbook
What it is	Sentinel-native rules engine for incident/alert handling	An Azure Logic App workflow
Triggers	When incident is created, when incident is updated, when alert is created	Incident trigger, alert trigger, entity trigger — usually invoked by an automation rule
Native actions	Run playbook , change status, change severity, assign owner , add tags, close incident	Anything Logic Apps can do: post to Teams/Slack, create a ServiceNow/Jira ticket, block an IP on the firewall, disable a user in Entra ID, isolate a machine in MDE, ask for approval by email
Ordering	Yes — rules have an order number and run in sequence	N/A
Conditions	Rich conditions on incident properties, entities, custom details	Inside the Logic App
Expiry	Can be set to expire on a date	N/A
Cost	Free	Billed as a Logic App (per action/connector)

How they fit together: an analytics rule creates an incident → an **automation rule** matches on conditions → it **runs a playbook** and/or sets properties.

- **Noise suppression** is the classic automation rule use: *"automatically close incidents from rule X when the account is a known service account"* → automation rule with conditions + **Change status: Closed** with classification Benign positive. No playbook needed.
- **Permissions:** Sentinel needs explicit permission on the playbook's resource group (**Microsoft Sentinel Automation Contributor**) for an automation rule to run it. Playbooks authenticate to targets via a **managed identity** or connection.
- Playbooks can also be run **manually** from an incident or entity.

Exam pattern: "When a high-severity incident is created, notify the SOC channel in Teams and create a ServiceNow ticket." →

Automation rule (trigger: incident created, condition: severity = High) → run playbook (Logic App). "Automatically close all incidents generated by a specific rule when they involve a test account." → **Automation rule only**, no playbook.

14. Content, cost, and retention

- **Content hub** — install **solutions** (packaged connectors, analytics rules, workbooks, hunting queries, playbooks, parsers). Replaces browsing individual templates.
 - **Workbooks** — visualisation and dashboards, built on Azure Monitor workbooks. *"Visualise the data"* → workbook.
 - **Log plans: Analytics** (full query, alerting, default 30 days included) vs **Basic/Auxiliary logs** (much cheaper, limited KQL, no alerting, short retention) vs **Archive** (up to 12 years) with **search jobs** and **restore** to bring data back. **Table-level retention** overrides workspace retention.
 - **Summary rules** — aggregate verbose logs into a compact table on a schedule, to cut cost while keeping trend visibility.
 - **Commitment tiers** for ingestion pricing; Sentinel P2 Defender for Servers gives **500 MB/day free ingestion** per server.
 - **SOC optimization** — recommendations to improve coverage or cut cost (e.g. an ingested table with no detections attached).
 - **Multi-workspace / Azure Lighthouse** for MSSP and multi-tenant scenarios; **workspace manager** for centralised rule deployment.
-

Rapid-fire self-test

1. Which Policy effect prevents non-compliant resources being created? → **Deny**
2. Which two effects need a **managed identity**? → **DeployIfNotExists** and **Modify**
3. How do you fix **existing** non-compliant resources? → **Remediation task**
4. Key Vault soft delete retention range and default? → **7–90 days, default 90; cannot be disabled**
5. Can purge protection be turned off once enabled? → **No**
6. Which Key Vault role can read a secret's **value**? → **Key Vault Secrets User** (Reader cannot)
7. Key Vault Premium vs Managed HSM FIPS level? → **140-2 Level 2 vs Level 3**
8. What drives Secure Score? → The **MCSB** initiative's recommendations
9. Which Defender for Servers plan has JIT, FIM, and agentless scanning? → **Plan 2**
10. How much free Log Analytics ingestion does Defender for Servers P2 include? → **500 MB per day**
11. Which agent does Defender for Servers now use for most features? → **None** — agentless scanning + **Defender for Endpoint**
12. Where did **Defender for DNS** go? → Folded into **Defender for Servers Plan 2**
13. Which Sentinel rule type runs **every minute**? → **NRT**
14. Which rule type produces **no alerts**? → **Anomaly** (writes to the `Anomalies` table)
15. Which two rule types stop working under Defender XDR incident integration? → **Microsoft security** and **Fusion**
16. What is required for the investigation graph to work? → **Entity mapping** on the analytics rule
17. Trigger on a Defender for Cloud recommendation → ? → **Workflow automation (Logic App)**
18. Trigger on a Sentinel incident → ? → **Automation rule** (which

may run a playbook)

19. Sentinel Azure portal end-of-support date? → **31 March 2027**